

I.B IT Responsibilities and Functions

Action Summary

As part of the governance structure, financial institution management should ensure development, implementation, and maintenance of the following:

- An effective IT risk management structure.
- A comprehensive information security program.
- A formal project management process.
- An enterprise-wide business continuity planning function.
- An accurate and timely process for information systems reporting.

I.B.1 IT Risk Management Structure

The institution should have an adequate ITRM structure. Depending on the size and complexity of the financial institution, this structure can take different forms. In a large or complex institution, the ITRM function may be an independent business unit.¹⁰ In a small or less complex institution, ITRM may be integrated with functional areas, such as information security, business continuity planning, third-party management, and regulatory compliance. Internal audit, specifically IT audit, can provide independent assurance on the effectiveness of risk management, but should not be responsible for its implementation. Regardless of the structure used, management should ensure that lines of authority are established for enforcing and monitoring controls.

I.B.2 Information Security

The institution should have a comprehensive information security program that addresses all technology and information assets and that complies with the Information Security Standards; these standards and the GLBA are discussed in detail in the “[Protecting Sensitive Customer Information](#)” section of this booklet. The information security program should include appropriate administrative, technical, and physical safeguards based on the inherent risk profile and the individual activities, products, and services of the institution. The board should delegate responsibility to the CISO or other appropriate personnel for assessing whether IT operations conform with policies. The CISO should ensure appropriate consideration of risks involved with new products, emerging technologies, and information systems. Testing of the controls identified in the information security program should be delegated to an independent auditor.¹¹

¹⁰ Some agencies have guidance on ITRM for larger, more complex financial institutions.

¹¹ An independent audit function can include internal auditors with sufficient independence to perform an adequate review, outside consultants or auditors, or a combination of both.

The institution should separate information security program management and monitoring from the daily security duties of IT operations. The IT department should have personnel with daily responsibility for implementing the institution's security policy. Responsibility for making changes and granting exceptions to policy should be segregated from the enforcement of the controls. Refer to the *IT Handbook's* "Information Security" booklet for more information.

I.B.3 Project Management

An effective project management process is a key factor in a well-managed IT operation and includes applying knowledge, skills, tools, and techniques to achieve project objectives. The operational complexity of the institution dictates the degree of formality of project management practices. Generally, project management consists of initiating, planning, executing, controlling, and completing projects. The institution's ability to manage projects drives its ability to adapt to changes in its business requirements and satisfy its strategic objectives. Management uses project management techniques to control projects for systems acquisition and development, systems conversions, product enhancements, infrastructure upgrades, and system maintenance.

Project teams should balance resource investments of time, money, and expertise with a project's priority, risk, and requirements. Management should monitor projects closely to control costs and assure adherence to project management policies. A formal project management system, if used, should employ well-defined and proven techniques for managing projects at all stages. Regardless of the system used, management should include the following elements in its project management process:

- Oversight by experienced and skilled project managers, whether they are employees of the institution or consultants hired for specific projects.
- Accepted and standardized project management practices.
- Senior management support, including a review process around significant projects.¹²
- Defined and monitored institution-wide project risk assessment methodology.
- Approval processes to ensure that projects are defined, go through a risk assessment process, and meet requirements.
- Established project requirements with collaboration among stakeholders and project management staff for each phase of the project.
- Target completion dates to track each task or phase of the project.
- Timely project status updates to compare actual completion dates with target dates.
- Procedures to track and measure project performance against requirements.
- A defined change management process, including approval requirements.
- Sufficient testing at all appropriate stages of the project to ensure that the new system or process will not negatively impact existing systems.
- Training for end users and designated staff responsible for ongoing support.
- A well-managed process for transition in ownership from implementation teams to operational teams.

¹² The significance of projects will depend on the institution's activities and its size and complexity.

Based on an institution's size and complexity, an institution pursuing a more-than-moderate growth path should consider establishing a project management office to promote sound management practices and principles. Refer to the *IT Handbook's* "Development and Acquisition" booklet for more information.

I.B.4 Business Continuity

Business continuity is defined as the ability to maintain operations and services, both technology and business, in the event of a disruption to normal operations and services. The board of directors should oversee implementation and approve policies relating to business continuity planning. Senior management should establish and implement policies, standards, and procedures and define responsibilities for enterprise-wide business continuity planning. Because business continuity is important for both business processes as well as technology operations, business continuity planning should be approached on an enterprise-wide basis. Business continuity planners should assess the ability for all lines of business to remain resilient or recover from disruptions or degradations. The business continuity function often resides in the risk management organizational structure. A specific member of management should be assigned responsibility for the oversight of the business continuity function, and both business and technology departments should assign personnel to develop and maintain the individual business unit plans. Refer to the *IT Handbook's* "Business Continuity Planning" booklet for more information.

I.B.5 Information Systems Reporting

A variety of systems can provide management with the information necessary to manage an institution effectively. These systems are often referred to as management information systems, decision support systems, and risk control self-assessments, to name just a few. While the precise definitions vary, these information systems are used by management to assess the performance of the business, report on the risks and challenges it faces, and assist management in the successful operation of the business.

Management should design its information systems to do the following:

- Provide management with information that is timely, accurate, consistent, complete, and relevant.
- Provide an objective system for recording and aggregating information.
- Provide key risk performance trends and indicators; and measure performance against risk tolerances.
- Support the institution's strategic plan.
- Ensure the confidentiality, integrity, and availability of data.
- Reduce labor-intensive manual activities.
- Enhance communication among staff.

Information systems reporting supplies decision makers with facts, supports and enhances the overall decision-making process, and can improve job performance throughout an institution. At the most senior levels, information systems reporting provides the data and information to help

the board and management make strategic decisions. At other levels, information systems reporting allows management to monitor the institution's activities and distribute information to staff, customers, and members of management.

Advances in technology have increased the volume of data and information available to management and directors for planning and decision making. Because report generation systems can rely on manual data entry or extract data from many different financial and transaction systems, management should establish appropriate control procedures to ensure that data and information are correct and relevant. Because information systems reporting can originate from multiple technology platforms, the controls should be designed to maintain the integrity of the information and the processing environment.

To function effectively as a feedback tool for management and staff, information systems reporting should meet five essential elements:

- **Timeliness:** To facilitate prompt decision making, an institution's information systems should be capable of providing and distributing current information to appropriate management or staff.
- **Accuracy:** A sound system of automated and manual internal controls should exist to ensure the validity of the information and should include appropriate editing, balancing, and internal control checks.
- **Consistency:** To be reliable, data should be processed and compiled in a uniform manner. Variations in data collection and reporting methods can distort information and trend analysis.
- **Completeness:** Reports should contain the necessary information to inform decision makers without voluminous detail.
- **Relevance:** Information systems should provide current, applicable, and actionable information.

In a complex institution, information systems reporting can be highly structured and automated. In a less complex institution, it can be informal and less dependent on sophisticated technology systems. Institution management should adopt information systems reporting capabilities commensurate with the size and complexity of the institution.

I.B.6 Planning IT Operations and Investment

Action Summary

Financial institution boards should oversee, while senior management should implement, an IT planning process with the following elements:

- Long-term goals and the allocation of IT resources to achieve them, usually within a three- to five-year horizon.
- Alignment of the IT strategic plan with the enterprise-wide business plan.
- Identification and measurement of risk before changes or new investment in technology are made.
- An IT infrastructure to support current and planned business operations.
- Integration of IT spending into the budgeting process and weighing of direct and indirect benefits against the total cost of ownership of the technology.

Planning involves preparing for future activities by defining goals and the strategies used to achieve them. Future activities may include releasing a new product or service, planning mergers and acquisitions, or preparing for the end of service for an IT system. IT is an integral part of financial institution operations. Therefore, institution management should integrate consideration of IT resources and investments into the overall business planning process. Major investments in IT resources have long-term implications on both the delivery and performance of an institution's products and services.

Plans may vary significantly depending on institutions' size and structure. Management should strive to achieve a planning process that constantly adjusts for new risks or opportunities and maximizes IT's value. Management should document its plan; a written plan, however, does not guarantee an effective planning process. Management should measure the effectiveness of a specific plan by whether the plan meets the institution's business needs. A sound plan should involve the board of directors, senior management, and staff in the planning process. The board of directors should provide a credible challenge to management when the board reviews and approves the plan. Senior management participates in formulating and implementing the plan. The individual departments and functional areas identify specific business needs and, ultimately, implement the plan.

An institution that uses third-party providers should verify that the provider can continue to support the institution's plans and that the plans and actions of the provider do not negatively impact the institution. As part of the institution's ongoing monitoring process, management should participate in third-party provider client user groups. Institution management should also consider a review of client portals, news articles, provider newsletters, and press releases to maintain awareness of provider activities, changes in strategy and products, future plans, and potential or actual service or security issues.

I.B.6(a) *Strategic IT Planning*

Strategic IT planning should address long-term goals and the allocation of IT resources to achieve them. Strategic IT planning focuses on a three- to five-year horizon and helps ensure that the institution's technology plans are consistent and aligned with the institution's business plan. Effective strategic IT planning can ensure delivery of IT services that balance cost and efficiency, while enabling the business units to meet the competitive demands of the marketplace. The IT strategic plan should address the budget, periodic board reporting, and the status of risk management controls.

Tactical plans support the larger IT strategic plan by defining specific steps necessary to fulfill it. Tactical plans outline specific steps, personnel, tools, and timetables to achieve the goals laid out in the IT strategic plan, typically using a one-year time frame. These tactical plans typically address hardware and software architecture, end-user computing resources, and processing done by third-party providers. These plans are often created by mid-level managers.

The operational IT plan is used to achieve the goals and objectives of both the tactical plans and the larger strategic plan. It provides the detailed information to perform the tasks needed to implement the tactical plans of an institution. The operational IT plan includes the milestones and tasks that must be undertaken, the individuals who have responsibility for each milestone and task, the timelines in which they must be completed, the conditions for success, and the financial resources necessary to complete each milestone and task. Operational plans should flow logically from both the tactical plans and the larger IT strategic plan. Front-line management typically creates and revises operational plans as needed based on changes in the underlying business needs.

Strategic IT planning should consider a number of factors:

- Marketplace conditions.
- Customer demographics.
- Institution growth targets.
- Mergers and acquisitions.
- Technology standards.
- Regulatory requirements (e.g., privacy, security, consumer disclosures, and other reporting requirements).
- Cost containment.
- Process improvement and efficiency gains.
- Customer service and technology performance quality.
- Third-party relationship opportunities versus in-house expertise.
- Optimal infrastructure, including systems and software replacement.
- Ability to adopt and integrate new technology.

These factors should align with the institution's business plans. Well-implemented IT plans enable the institution to deliver business value in terms of market share, earnings, and capital growth. If used, the IT steering committee's cross-functional membership makes the committee well-suited for balancing or aligning the institution's IT investment with its strategic objectives.

Typically, institutions that align IT with changing business goals and objectives have more effective operations.

Technology expenditures should be commensurate with the financial condition of the institution. They should also be appropriate to meet the changing IT strategy, provide enterprise-wide value, support necessary growth, ensure appropriate security and business resilience, and mitigate technology incompatibilities. For example, delaying investments and spending too conservatively on infrastructure or new products may lead to ineffective operations and service levels. Without a full understanding of the available technology, the institution is not able to update processes and products or achieve productivity gains or increased revenues. To create the appropriate balance, institutions should link strategic and operational plans between IT and the business units.

Management should address the following four key factors of IT planning:

- **Senior management participation:** Senior management should understand and support the IT strategic plan and established priorities.
- **Role of IT:** Management should clarify the role of IT and determine whether the current IT planning process enables personnel to work toward achieving enterprise-wide goals and objectives.
- **Impact of IT infrastructure:** Management or the IT steering committee should understand the relationship between the IT infrastructure and applications and the business strategic and operating plans. The IT infrastructure should directly support the goals and objectives of these plans.
- **Accurate scorecard on past performance:** Management or the IT steering committee should monitor past IT projects and initiatives after implementation to determine whether the institution realized the anticipated costs and benefits. The scorecard should be based on a set of objective measures.

Management should also create and maintain an alignment between IT and enterprise-wide strategies by performing the following:

- Reviewing whether IT strategic plans are aligned with the business strategy.
- Reviewing whether IT performance supports the planned strategy.
- Ensuring that the IT department is delivering on time, within budget, and to specification.
- Balancing investments between systems that support current operations and systems that transform operations and enable business units to grow and compete in new areas.
- Focusing IT resource decisions on specific business objectives, such as entry into new markets, enhanced competitive position, revenue growth, improved customer satisfaction, or customer retention.

I.B.6(b) *IT Resources*

Management should provide IT resources that are adequate to meet the current operational needs of the institution. Operational planning should consider the impact of any changes on critical business processes. Business processes are the integration of people, technology, and procedures

used to accomplish a task or complete a transaction. Changes in business processes should be coordinated and aligned with available IT resources. IT resources include the following elements:

- **Infrastructure:** Power, telecommunications capacity, network architecture, and facilities.
- **Hardware:** Mainframes, network servers, personal computers, communications networks, mobile devices, storage devices, and peripherals.
- **Operating software:** Operating systems, compilers, and utilities designed to enable the equipment and applications software to function effectively, both internally and externally.
- **Application software:** Programs designed to permit application users to perform a specific task or function. Application software runs on top of operating system software.
- **Personnel:** Staff and training programs.

Management should consider sufficient capacity for current and future needs for each of these elements.

I.B.6(c) *Budgeting*

Budgeting is another step in the operational planning process. The board should assess management's plans and its success in defining and meeting budgetary goals as one means of evaluating management's performance. The budget is a coordinated financial plan used to estimate and control the institution's activities. By assessing future economic developments and conditions, management creates an action plan and records changes in the balance sheet accounts and profitability (predicated on implementation of the plan). The budget not only projects expected results, but also serves as an important check on management.

When considering new IT projects, management should look at the entry costs of the technology and the post-implementation support costs. Increasingly, institutions are demanding, and third-party providers are providing, information regarding the total cost of ownership (TCO) beyond initial entry costs. IT projects often have undocumented costs, including the resources required to configure, maintain, repair, support, upgrade, and manage the technology over its lifetime. Readily available TCO models, as well as historical data, provide management with tools to incorporate such costs into the selection and budgeting process.

Some institutions budget IT as a separate department. A financial analysis of an IT department should include a comparison of the cost-effectiveness of the in-house operation versus contracting with a third-party provider. The analysis may also include a peer group comparison of operating costs and ratios. Depending on its size and complexity, the institution may allocate costs to the institution's lines of business. When cost allocation is used, management should ensure equitable assignment of the costs to each line of business. Equitable assignment of the costs is often accomplished by use of a chargeback system that records usage of resources based on a performance metric such as central processing unit cycles.

In some instances, a separate subsidiary of the holding company manages the IT function. An IT subsidiary can provide essential services at costs below those of third-party providers or individual institutions. Some relationships, however, may not result in a cost savings. Any

transaction between the institution and its affiliates must comply with applicable laws and regulations.¹³ Refer to the *IT Handbook*'s "Outsourcing Technology Services" booklet for more information.

I.B.7 Other Functions

Action Summary

The IT function at a financial institution is influenced by several other functions, which should include the following:

- The human resources function should hire and maintain competent and motivated IT staff.
- The IT audit function should validate appropriate controls to mitigate IT risk.
- The compliance function should validate that systems and applications adhere to applicable laws and regulations.

I.B.7(a) Human Resources

Human resources (HR) supports the IT function's ability to hire and maintain a competent and motivated staff. IT management should integrate its management of HR with IT planning to ensure optimum development and availability of IT skills.

Components of an effective IT HR management process include compensation planning, performance reviews, knowledge transfer mechanisms (e.g., rotational assignments), training, and mentoring. The board should actively and effectively provide oversight of incentive compensation programs for IT management to ensure that the programs appropriately balance risk and reward and are compatible with effective controls and risk management.

An institution should have programs in place to ensure that staff members have the expertise necessary to perform their jobs and achieve company goals and objectives. The institution may need to look externally to find necessary expertise for specialized areas.

¹³ Sections 23A and 23B of the Federal Reserve Act, codified at 12 USC 371c and 12 USC 371c-1, govern transactions between certain financial institutions, such as Federal Reserve member banks, national banks, and federal savings associations, and the institutions' affiliates. Specifically, section 23B(a) states that an institution and its subsidiaries may engage in certain transactions with an affiliate, including the payment of money or the furnishing of services to an affiliate under contract, lease, or otherwise. The transactions must be on terms and under circumstances, including credit standards, that are substantially the same, or at least as favorable to such institution, as those prevailing at the time for comparable transactions with or involving other nonaffiliated companies. In the absence of comparable transactions, the statute requires that such transactions be on terms and under circumstances, including credit standards, that in good faith would be offered to, or would apply to, nonaffiliated companies. See 12 USC 371c-1(a).

Management should develop training programs for new technology and products before their deployment in the institution. The institution may use its own certification program or encourage employees to obtain an external certification to ensure that the staff maintains the necessary expertise to support the business.

The board and senior management should consider appropriate succession and transition strategies for key managers and staff members. Some strategies include the use of employment contracts, professional development plans, and contingency plans for interim staffing of key management positions. Management should have backup staff for key positions and should cross-train additional personnel. The objective is to provide for a smooth transition in the event of turnover in vital IT management or IT operations.

I.B.7(b) *IT Audit*

The audit department should send IT audit reports to appropriate management and directly to the board of directors or a designated board committee. The board of directors is responsible for overseeing the IT auditors' performance and compensation, including whether the IT auditors have the necessary expertise and the audit coverage is adequate, timely, and independent. Depending on the institution's size and complexity, the board of directors may completely outsource the IT audit function. In those cases, the outsourced auditor should be engaged by the board or audit committee.

IT auditors should validate that IT controls are designed appropriately to mitigate risk and are operating as management intended. IT audit should be completely independent, should have no role in designing or implementing controls, and should not have primary responsibility for enforcing policy. Management should have processes in place to monitor and enforce policy compliance. IT audit should verify that those processes function effectively and report the results to the board.

Senior management should ensure cooperation between business unit management and IT audit. Management should also ensure timely and accurate response to audit concerns and exceptions and ensure appropriate and timely corrective action.

Refer to the *IT Handbook's* "Audit" booklet for more information.

I.B.7(c) *Compliance*

Senior management should ensure that compliance staff reviews new products, systems, applications, or changes to ensure compliance with applicable laws and regulations. New implementations or changes can cause noncompliance through, for example, inaccurate interest rate calculations, inadequate or inaccurate disclosures, weak security controls over the creation, storage, or transmission of customer information, or poor customer verification procedures.